CAPACITACIÓN TÉCNICA · BANCO DE MÉXICO

Módulo 3. A04

Fallos Criptográficos



Desarrollo Seguro de Sistemas (OWASP) · Banco de México
Java JDK 17 · Jakarta EE 11 · PostgreSQL 16

50 diapositivas · A03:2025 y A04:2025 · Casos y ejercicios hipotéticos

A04:2025 · Fallas Criptográficas



La categoría ocupa el lugar #4

Incluye fallas relacionadas con:

- Ausencia de criptografía.
- Algoritmos, protocolos o parámetros débiles.
- Exposición o mala gestión de claves.
- Aleatoriedad insuficiente.
- Errores de implementación o validación.

APLICACIÓN / DISCUSIÓN

Requiere diseño, implementación, configuración y operación correctos.

Qué debe protegerse



Clasificar antes de elegir controles

Identificar datos:

- Públicos.
- Internos.
- Confidenciales.
- Sensibles o regulados.

Considerar datos procesados, almacenados y transmitidos; también copias, logs, respaldos, cachés y exportaciones.

APLICACIÓN / DISCUSIÓN

Archivos de conciliación contienen identificadores, importes y datos ficticios de participantes.

Datos en tránsito



Proteger los canales de comunicación

- Usar TLS y configuraciones robustas.
- Rechazar certificados inválidos o cadenas no confiables.
- Evitar HTTP y protocolos sin cifrado.
- Deshabilitar versiones y suites débiles.
- Aplicar HSTS en aplicaciones HTTPS.
- Revisar comunicaciones internas y APIs.

APLICACIÓN / DISCUSIÓN

Una API interna transmite credenciales y datos sin protección de transporte.

Datos en reposo



Cifrar donde el riesgo lo exige

Evaluar cifrado para:

- Bases de datos y volúmenes.
- Archivos y exportaciones.
- Respaldos.

Acompañar con gestión de claves, acceso y retención mínima.

APLICACIÓN / DISCUSIÓN

Un respaldo de PostgreSQL contiene operaciones y queda fuera del perímetro controlado.

Algoritmos y protocolos obsoletos



No diseñar criptografía propia

Evitar:

- MD5 y SHA-1 para usos criptográficos actuales.
- Algoritmos o suites débiles/obsoletas.
- Configuraciones que permiten downgrade.

Usar bibliotecas estándar y configuraciones revisadas.

APLICACIÓN / DISCUSIÓN

La selección concreta depende del estándar institucional y caso de uso.

Hash, cifrado y firma + Aleatoriedad criptográfica



Tres funciones distintas

Hash: huella unidireccional.

Cifrado: protege confidencialidad y requiere clave para descifrar.

Firma digital: permite verificar integridad y autenticidad mediante claves.

No son intercambiables ni resuelven por sí solos todos los requisitos.

Complemento:

- Usar generadores criptográficamente seguros (CSPRNG).
- No usar Random común para secretos.
- No sembrar con hora o identificadores predecibles.
- Respetar requisitos de nonce/IV del algoritmo.
- No reutilizar nonces cuando el modo lo prohíbe.

APLICACIÓN / DISCUSIÓN

Un hash de archivo no sustituye una firma confiable del artefacto liberado. · Un token de descarga generado con contador secuencial puede adivinarse.

PostgreSQL 16: protección de datos



La base de datos no reemplaza el diseño criptográfico

- TLS entre aplicación y PostgreSQL.
- Cifrado de disco/volumen y respaldos.
- Roles mínimos y separación de funciones.
- No registrar secretos ni datos completos.
- Cifrado de aplicación si se requiere protección por campo.
- Gestión externa y rotación de claves.

APLICACIÓN / DISCUSIÓN

Un rol de reportes consulta vistas con datos minimizados.

Caché, logs y copias



Los datos sensibles se filtran fuera de la tabla principal

Revisar:

- Caché CDN, web y aplicación (p. ej. Redis).
- Logs y trazas.
- Dumps y respaldos.
- Archivos temporales y exportaciones.
- Mensajes de error y telemetría.

Deshabilitar caché de respuestas sensibles y minimizar registros.

APLICACIÓN / DISCUSIÓN

Una respuesta financiera queda almacenada en una caché compartida.

TLS, HSTS y pruebas



Verificar la configuración, no asumirla

- TLS 1.2 o superior, conforme al estándar aprobado.
- HSTS para sitios HTTPS cuando corresponda.
- Deshabilitar protocolos y suites débiles.
- Verificar certificados y cadena.
- Probar downgrade y endpoints heredados.
- Revisar balanceadores y proxies.

APLICACIÓN / DISCUSIÓN

Verificar toda la ruta de comunicación con herramientas.